Data Breach and its Significance

- **What is Data Breach?**

Data breach incident is an event where confidential, sensitive, or protected information is leaked, copied, or stolen by an unauthorized individual without the knowledge of the system or data owner (Khan et al.,2019). Based on the Personal Data Protection (Amendment) Act 2024, *"personal data breach means any breach or personal data, loss of personal data, misuse of personal data or unauthorized access of personal data".*

- **The Rise of Data Breach Cases in Malaysia**

The recent statistics showed that data breach reports in Malaysia have increased significantly from only 50 cases in 2022 to 646 cases in 2023. And as of September 2024, 427 data breach cases have been recorded for the year (San et al., 2024).

Over these past years, Malaysia has experienced a series of major data leakage. For example, in September 2021, an estimated of 4 million records on Malaysians born from 1979 to 1998 is up for sale on the dark web for about 0.2 bitcoin which equivalent to RM 35,000 at the current cryptocurrency exchange. It was complete with personal details such as phone numbers, MyKad and home address (Ismail, 2021). Then, in May 2022, a sequential incident happened where 22.5 million data on Malaysians born from 1940 to 2004 was being sold for $10,000 or RM43,890 on the dark web (Satar, 2022).

These data breach incidents could lead to serious impact where the perpetrators who obtain these personal data may attempt to perform cybercrimes activities such as scamming Malaysians via calls or impersonating citizens to take out loans.

- **Impacts of Data Breaches in Today's Digital Landscape**

Malaysia Computer Emergency Response Team (MyCERT) Advisory (2019) outlined some serious impact of data breach which are:

a) *Risk to individual's safety*

Disclosure of sensitive personal information on the dark web may bring harms to individuals whose information is exposed such as identity theft and fraud.

b) *Financial loss to an individual or organisation*

Perpetrators often extorts money from the organization involved and threaten to sell the data on dark web if the ransom is not being paid in the given timeframe.

c) *Damage to personal reputation or position*

If the data is reported to be leaked, individuals or organization who is accountable for the data will be condemn by the public for their negligence to protect the data.

d) *Loss of public trust in an Agency or the services it provides*

Organisation who fails to protect confidential information of their customers will lose the public trust due to their incompetency.

e) *Exposure of commercially sensitive information to third parties*

Exposure of confidential business information provides an advantage for competitors to sabotage or steal opportunities to stay ahead.

f) *Threat to an Agency's systems, impacting the capacity to provide services*

The compromised systems will be temporarily unavailable, and the service provided will be delayed due to the effort needed to do recover the system and forensic investigation to identify the origin and extent of the breach.

g) *Impact on Government reputation, finances, interests or operation.*

Breach incidents involving government's data may threaten the country's economy, stability and jeopardize its credibility and national security.

h) *Loss of data integrity*

Data that is leaked may be altered or corrupted, thus may affect the confidence in decision-making as the data source may not be accurate.

Types of Data Breach

Data breach can occur due to various reasons, for instances, human errors, computer system error, and malicious activity. In this section, two approaches to classify the type of data breach will be discussed. The first approach is to classify the data breach threats based on causes either intentionally or unintentionally. The second approach is to classify the data breach based on parties that caused the data leakage either internal or external.

- **First Approach: Intentional vs Unintentional Data Breach**

Intentional data breach is a deliberate incident caused by malicious activity exploiting vulnerabilities with the intention to bring harm to an organization. Correspondingly, there are four common factors related to intentional data breaches (Khan et al., 2019).

1) **Hackers** may break into system via attacks in structured query language (SQL) injection or using spyware, viruses, malware, or phishing.

2) **Malicious insiders** are the company's own employees who violates the security and privacy policy to steal intellectual property for personal gain.

3) **State sponsored actors** are government-backed entities consist of capable threat agents to sabotage or conduct cyber espionage on other country for their nation's interest.

4) **Terrorists** may involve in cyber-attacks for propaganda, political, or ideological purposes resulting in violence against targeted subject or to instill fear on an organization.

On the contrary, unintentional data breach is an accidental incident without malicious intention. Accordingly, there are five typical factors of unintentional data breaches incidents (Khan et al., 2019).

1) **Unsecured user behaviour** such as using weak passwords, re-used passwords across different systems, or sharing passwords among colleagues which ease the attacker to guess the credentials based on history sign-in.

2) **Misplacing devices** that contain confidential data may lead to data breach if it was stolen and fall into the wrong hands.

3) **Flawed software** due to not performing regular system updates also cause data breach because the software may become vulnerable hence the attackers can exploit the device easily.

4) **Unintentional disclosure** such as emailing sensitive information to the wrong recipients or misconfigured sharing settings allowing unauthorized people to have access.

5) **Pirate software** might be risky to use for company's purposes as virus and malware can be easily distributed over unauthorized software.

- **Second Approach: Internal vs External Data Breach Threats**

Data breach incidents can be originated from insider or outsider threats. Internal data breach is a bit complicated as it involves users that have authorized access to the systems and database. Their actions might not leave trail as they know how to bypass the system detection (Cheng et al., 2017).

Internal data breach may happen intentionally by malicious employees due to their dissatisfaction with the company or was offered financial rewards by competitors' company. Besides, it can also happen by accident due to human error because lack of security awareness in workplace. Example of internal data breach includes the exposure of customers' Personally Identifiable Information (PII) on public website due to employee negligence. Second example is, recently fired employee stole the confidential company data to share with competitors upon termination (Cheng et al., 2017).

In contrast, external data breach typically caused by cybercriminals through hacking, malware, virus, and phishing. The perpetrators might have meticulously plan to infiltrate the system backdoor or disable the access control to bypass the system's authentication settings and ultimately gain access to private and sensitive information. The perpetrators might also fool the employees by disguising fraudulent message to appear legitimate so that the employees are not suspicious with it and shares the valuable information to them (Cheng et al., 2017).

Data Protection Laws, Regulations and Compliance

- **Example of Data Protection Laws and Regulations in other Countries**

a) European Union General Data Protection Regulation (EU GDPR)

European Union General Data Protection Regulation (EU GDPR) is enforced in 2018 to govern data protection and privacy of citizens within European Union (EU) and European Economic Area (EEA). This regulation replaced the Data Protection Directive of 1995, aiming to not only providing comprehensive legal frameworks that protects personal privacy but also corresponds to current challenges arise with the advancement in technology (Bakare et al., 2024).

EU GDPR empowers individuals with set of rights over their data. Some rights that were emphasize includes the right to be informed of how the personal data is being used, the right of access for personal data being process, the right to rectify incorrect personal data, and the "right to be forgotten" to erase the personal data.

Meanwhile, data controllers are obligated to comply to principles of "lawfulness, fairness, and transparency". Furthermore, Article 25 of EU GDPR introduces the concept of "data protection by design and by default" which encourage organizations to embed data protection and security measures throughout their systems and processes.

In the case of non-compliance and infringement of the regulations, the EU GDPR imposes significant fines of up to €20 millions or 4% of annual global revenue, whichever is higher.

b) Health Insurance Portability and Accountability Act (HIPAA)

In the other hand, the United States has a fragmented regulatory landscape in which it does not have a comprehensive federal privacy law and focuses on a sector-specific laws and state regulations. The Health Insurance Portability and Accountability Act of 1996 (HIPAA) was enacted on 21 August 1996 to specifically address the privacy and security of health information ensuring its confidentiality, integrity, and availability.

This law applies to covered entities such as health plans, healthcare providers, and healthcare clearinghouses to protect the sensitive health data (Bakare et al., 2024).

The HIPAA Privacy Rule and HIPAA Security Rule was established by the Secretary of the U.S. Department of Health and Human Services (HHS) prior to statement in Sections 261 until 264 of HIPAA in which it requires HHS to publish standards on protecting the privacy and security of health information. In short, Privacy Rule is a standard to protect the individually identifiable health information known as "protected health information" (PHI), while Security Rule provides standard to safeguard the subset of information covered by the Privacy Rule which is the "electronic protected health information" (e-PHI).

The individuals' rights that are covered by HIPAA includes the right to be informed in which the covered entities must provide a "Privacy Practice Notice" to describe the uses and disclosure of PHI in their practice. Besides, the individuals also have the right to review and obtain copy of PHI, the right to amend inaccurate or incomplete PHI, the right to an accounting of the disclosures of their PHI, the right to restrict the disclosure of PHI, and the right to request alternative communications medium to receive confidential PHI.

As per Sections 1176 in HIPAA, a person who fails to comply with requirements or standards will be imposed civil money penalty of $100 per failure or not more than $25,000 per year for multiple violations. Meanwhile, in Sections 1177, the criminal penalties for a person who wrongfully disclose PHI will face a fine of $50,000 and up to one-year imprisonment. The penalties may increase to $100,000 and up to five-years imprisonment if the wrongful conduct involves false pretenses. Furthermore, if it found out that the person has intent to sell or use the PHI for personal gain, commercial advantage, and inflict malicious harm, the penalties will rise to $250,000 and up to ten-years imprisonment.

- **Data Protection Laws and Regulations in Malaysia**

a) Personal Data Protection Act

The Personal Data Protection Act 2010 (PDPA) is a Malaysia's first comprehensive personal data protection legislation. It was passed by the Malaysian Parliament on 2 June 2010 and started to be implemented on 15 November 2013. PDPA is applied to any person who process or has control over personal data that can be used for commercial purposes. It is to govern the processing of personal data in commercial transactions by data users and to protect the interests of data subjects (Baskaran et al., 2020).

Currently, there are 13 classes of data users that are required to register under the PDPA such as banking and financial institutions, health, insurance, education, communication, real estate, and money lender (DLA Piper, 2023). As of now, there are nine Code of Practice published to create guidelines and enforce data users' compliance with PDPA such as Personal Data Protection General Practice and Personal Data Protection Code of Practice for Banking Sector and Financial Institutions.

According to Part II Division 1 in PDPA, data users are legally obligated to comply with seven personal data protection principles. They are "General Principle"; personal data cannot be processed without consent, "Notice and Choice Principle"; data subjects must be informed about the purpose of data collection and given choice to limit the consent, "Disclosure Principle"; personal data cannot be disclosed without consent, "Security Principle"; data users must apply appropriate security measures to safeguard personal data, "Retention Principle"; personal data can only be kept for a certain period, "Data Integrity Principle"; the personal data shall be ensured of its accuracy, and "Access Principle"; data subjects has access to their personal data and can request to amend or update the information.

Some penalties stated in PDPA includes fines of up to RM100,000 or up to one year imprisonment or both in the case of non-compliance with code of practice. Meanwhile, for the case of transferring personal data outside Malaysia, it will be penalized up to RM 300,000 or up to two years imprisonment or both. And for the case of illegally collecting personal data will be fined up to RM500,000 or imprisonment up to three years or both.

- **Ensuring compliance and resilience for a secure data environment.**

  All organization has an accountability to prevent and manage data breach incident. MyCERT Advisory (2019) provided guidelines that can be followed to prevent data breach from occurring.

  a) *Provide training on security awareness:* Employees need to be train on how to identify potential threats and respond appropriately to ensure a secure organization.

  b) *Good security hygiene:* System administrators need to properly configure databases and cloud repositories to avoid targeted attack by hacking group.

  c) *Invest in the right security technology:* Other than firewalls, intrusion detection, and antivirus systems, organizations should also consider using encryption and backup policy to reduce risk.

  d) *Patched regularly:* Software must be updated and patched routinely to minimize network vulnerabilities.

  e) *Comply with data protection regulations:* Organizations can ensure compliance by developing data security policy to protect data from risk coming from both outside and inside organization.

  f) *Perform regular vulnerability assessments:* Vulnerability assessment and security audit need to be done regularly to understand the security status of the data, prioritize security threats, determine the risk, and plan actions to be taken for data protection.

  g) *Ensure the principle of least privilege:* The access to sensitive information should be restricted to a need-to-know basis only.

  h) *Develop a data breach management plan:* A data breach management plan should comprise a clear explanation on data breach, ways to report data breach, strategy to respond to a data breach, and roles and responsibilities of each member.

References

Bakare, S. S., Adeniyi, A. O., Akpuokwe, C. U., & Eneh, N. E. (2024). DATA PRIVACY LAWS AND COMPLIANCE: A COMPARATIVE REVIEW OF THE EU GDPR AND USA REGULATIONS. *Computer Science & IT Research Journal*, *5*(3), 528–543. https://doi.org/10.51594/csitrj.v5i3.859

Baskaran, H., Yussof, S., Rahim, A., & Abu Bakar, A. (2020). Blockchain and The Personal Data Protection Act 2010 (PDPA) In Malaysia. *2020 8th International Conference on Information Technology and Multimedia (ICIMU)*, 189–193.

Cheng, L., Liu, F., & Yao, D. (Daphne). (2017). Enterprise data breach: causes, challenges, prevention, and future directions. *WIREs Data Mining and Knowledge Discovery*, *7*(5). https://doi.org/10.1002/widm.1211

DLA Piper. (2023). DATA PROTECTION LAWS OF THE WORLD - Malaysia. In *DLA PIPER*. https://www.dlapiperdataprotection.com/index.html?t=law&c=MY

Ismail, A. R. (2021, September 28). [UPDATE] JPN Data Of 4 Million Malaysians, Aged 23 To 42, For Sale Online. *The Rakyat Post*. https://www.therakyatpost.com/news/2021/09/28/nrd-data-of-4-million-malaysians-aged-23-to-42-for-sale-online/

Khan, F., Kim, J. H., Moore, R., & Mathiassen, L. (2019). Data Breach Risks and Resolutions: A Literature Synthesis . *AMCIS 2019 Proceedings*, *14*. https://aisel.aisnet.org/amcis2019/info_security_privacy/info_security_privacy/14/

Malaysian Parliment. (2010). *The Personal Data Protection Act 2010 (PDPA)*. https://www.pdp.gov.my/ppdpv1/en/akta/pdp-act-2010/

Malaysian Parliment. (2024). *Personal Data Protection (Amendment) Act 2024*. https://www.pdp.gov.my/ppdpv1/akta/pdp-amendmentact-2024/

MyCERT Advisory. (2019, September 27). *MA-746.092019: MyCERT Advisory - Security Best Practices on Data Breach Incident*. CyberSecurity Malaysia. https://www.mycert.org.my/portal/advisory?id=MA-746.092019

San, K. G., Carvalho, M., & Ibrahim, J. (2024, October 17). Data breaches surge 1192%: Minister warns of national security threat. *The Star*. https://www.thestar.com.my/news/nation/2024/10/17/data-breaches-surge-1192-minister-warns-of-national-security-threat

Satar, A. (2022, May 23). Is your personal data on the dark web? *TheSun*. https://thesun.my/opinion-news/is-your-personal-data-on-the-dark-web-BC9235416

The European Parliament and The Council of The European Union. (2016). *General Data Protection Regulation (GDPR)*. https://gdpr-info.eu/

United States Congress. (1996). *Health Insurance Portability and Accountability Act of 1996 (HIPAA)*. https://aspe.hhs.gov/reports/health-insurance-portability-accountability-act-1996